

Botium Toys Audit Exercise

Google Cybersecurity Professional Certificate



Index

Index.....	2
Activity summary.....	3
Scenery.....	3
Conducting the audit. Checklist and conformity.....	4
Audit:.....	5
1. Executive summary.....	5
2. Audit scope and objectives.....	6
3. Risk assessment.....	7
4. Controls Checklist.....	7
5. Compliance checklist.....	9
5.1 Payment Card Industry Data Security Standard (PCI DSS).....	9
5.2 General Data Protection Regulation (GDPR).....	9
5.3 System and Organization Controls (SOC 1 / SOC 2).....	10
6. Recommendations.....	10
Note.....	11

Activity summary

In the first part of this activity, you will conduct an internal security audit.

Audits help ensure that security checks are performed to manage threats, risks, or vulnerabilities that could affect business continuity and an organization's critical assets.

Scenery

This scenery is based on a fictional company:

Botium Toys is a small U.S.-based company that develops and sells toys. The company has a single physical location serving as its headquarters, storefront, and product warehouse.

However, Botium Toys' online presence has grown, attracting customers both within the U.S. and abroad. Consequently, its Information Technology (IT) department faces increasing pressure to support its global online market.

The IT manager has decided that an internal IT audit is necessary. She is concerned about maintaining compliance and business operations as the company expands without a clear plan. She believes an internal audit can help better protect the company's infrastructure and assist in identifying and mitigating potential risks, threats, or vulnerabilities regarding critical assets. The manager also wants to ensure compliance with regulations concerning internal payment processing, online payment acceptance, and conducting business within the European Union (EU).

The IT manager begins by applying to the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF), establishing the audit scope and objectives, listing assets currently managed by the IT department, and completing a risk assessment. The goal of the audit is to provide an overview of the risks and/or fines the company might face given the current state of its security posture.

Your task is to review the IT manager's scope, objectives, and risk assessment report. Then, conduct an internal audit by completing a controls and compliance checklist.

Conducting the audit. Checklist and conformity.

Conduct the security audit by completing the controls and compliance checklist.

To complete the checklist, open the supporting materials provided in Step 1. Then:

Review the *Botium Toys: Scope, Objectives, and Risk Assessment Report*, focusing on:

The assets currently managed by the IT department

The bullet points under "Additional Comments" in the Risk Assessment section

Consider the information provided in the report alongside the *Control Categories* document.

Audit:

1. Executive summary

Botium Toys' IT department commissioned this internal audit in response to the growth of its online market, which now serves customers in the United States and the European Union. The objective is to provide an overview of the risks and potential penalties associated with the current state of its security posture, and to determine which controls and compliance best practices should be implemented.

The audit was structured using the NIST Cybersecurity Framework. The scope, objectives, and risk assessment prepared by the IT manager were reviewed, and control and compliance checklists (PCI DSS, GDPR, and SOC 1/2) were completed.

Main conclusion: Botium Toys presents a high risk.

The most serious deficiencies concern regulated data—unrestricted access to card information and PII, and a lack of encryption—representing simultaneous non-compliance with PCI DSS and GDPR. The absence of backups and a recovery plan also threatens business continuity.

2. Audit scope and objectives

Scope: The entire Botium Toys security program, including employee equipment and devices, the internal network, and company systems. It encompasses a review of assets as well as existing controls and compliance practices.

Objectives: To evaluate existing assets and complete control and compliance checklists in order to determine which measures should be implemented to improve the company's security posture.

Assets currently managed by the IT department:

- On-site equipment for office business needs.
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, and surveillance cameras.
- Products available for retail sale (in-store and online), stocked in the adjacent warehouse.
- Management of systems, software, and services: accounting, telecommunications, databases, security, e-commerce, and inventory.
- Internet access, internal networking, and data retention and storage.
- Maintenance of legacy (end-of-life) systems requiring human monitoring.

3. Risk assessment

Asset management is inadequate. Botium Toys lacks all appropriate controls and may not be fully compliant with U.S. and international regulations. Under the "Identify" function of the NIST CSF, the company must allocate resources to identify and classify its assets and determine the impact of their loss on business continuity.

Potential impact: medium, because the IT department is unaware of which assets would be at risk. The risk of regulatory sanctions is high due to the lack of controls and the failure to fully adhere to compliance best practices that keep critical data private and secure.

Current Strengths:

Deficiencies / Gaps

- ✓ Firewall that filters traffic based on a properly defined set of security rules.
- ✗ All employees have access to internal data, including card data and PII/SPII.
- ✓ Antivirus software installed and regularly monitored.
- ✗ No encryption used for credit card data.
- ✓ Data integrity and availability controls implemented.
- ✗ Neither the principle of least privilege nor segregation of duties has been implemented.
- ✓ Breach notification plan for EU customers within 72 hours (GDPR).
- ✗ No intrusion detection system (IDS) in place.
- ✗ Privacy policies developed, documented, and enforced.
- ✗ No disaster recovery plans or data backups.
- ✗ Adequate physical security: locks, up-to-date CCTV, and fire detection/prevention systems.
- ✗ Minimal password policy; no centralized management system.

- ✗ Maintenance of legacy systems lacks a regular schedule and clear procedures.

4. Controls Checklist

Does Botium Toys currently have this control in place? (Yes / No)

Yes/No	Control / Best practice
--------	-------------------------

✗	Least privilege
---	-----------------

✗	Disaster recovery plans
---	-------------------------

✓ Password policies (implemented but inadequate)

✗ Segregation of duties

✓ Firewall

✗ Intrusion Detection System (IDS)

✗ Backups

✓ Antivirus software

✓ Legacy system monitoring/maintenance (implemented but inadequate)

✗ Encryption

✗ Password management system

✓ Locks (offices, store, warehouse)

✓ CCTV video surveillance

✓ Fire detection/prevention

5. Compliance checklist

Does Botium Toys currently adhere to this compliance best practice? (Yes/No)

5.1 Payment Card Industry Data Security Standard (PCI DSS)

Yes / No	Control / Best practice
----------	-------------------------

- | | |
|---|--|
| ✗ | Only authorized users access credit card information. |
| ✗ | Card information is stored, accepted, processed, and transmitted internally within a secure environment. |
| ✗ | Data encryption procedures to secure card transaction points. |
| ✗ | Secure password management policies. |

5.2 General Data Protection Regulation (GDPR)

Yes / No	Control / Best practice
----------	-------------------------

- | | |
|---|---|
| ✗ | EU customer data is kept private and secure. |
| ✓ | There is a plan in place to notify EU customers within 72 hours in the event of a breach. |
| ✗ | Data is properly classified and inventoried. |
| ✓ | Privacy policies and processes are implemented to document and maintain the data. |

5.3 System and Organization Controls (SOC 1 / SOC 2)

Yes / No	Control / Best practice
✗	User access policies have been established.
✗	Sensitive data (PII/SPII) is confidential and private.
✓	Data integrity ensures that data is consistent, complete, accurate, and validated.
✓	Data is available to individuals authorized to access it.

6. Recommendations

Recommendations prioritized by risk level, intended for the IT manager to communicate to stakeholders in order to reduce risk to assets and improve the security posture.

Critical

Encrypt regulated data and implement access controls. Currently, all employees can access card data and PII/SPII, and no encryption is used. This simultaneously violates PCI DSS and GDPR, exposing the company to fines and data breaches. Implement encryption (at rest and in transit) and apply the principles of least privilege and separation of duties to restrict access solely to those who require it.

High

Ensure business continuity. There are no backups or disaster recovery plan in place; a single incident (such as ransomware or hardware failure) could result in the irreversible loss of critical data. Establish regular backups and document a recovery plan.

Medium

Add the missing control layers. Install an intrusion detection system (IDS) to complement the existing firewall. Deploy a centralized password management system and enforce a stricter policy (minimum of 8 characters, including letters, numbers, and symbols), which would also reduce the number of password recovery tickets affecting productivity.

Medium

Manage assets (NIST CSF "Identify" function). Classify and inventory assets and determine the impact of their loss on business continuity. The absence of this inventory is what keeps residual risk high. Also, establish a formal maintenance schedule for legacy systems.

Note

When presenting these findings to management, it is advisable to frame the shortcomings in terms of business risk—such as regulatory fines, data loss, and operational disruption—rather than solely in technical terms, as this is what justifies budget allocation. Existing strengths do not require new investment, only ongoing maintenance.